



Weekly Cyber Threat Intelligence Report

Reporting window: 1 - 8 September 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

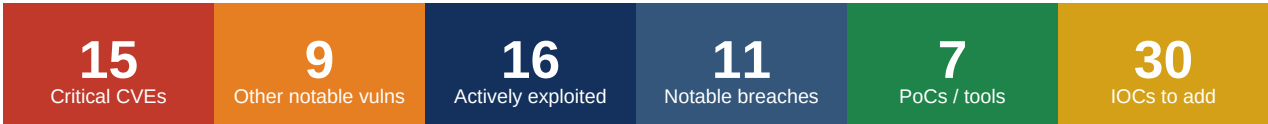
Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



Three themes dominated this window. First, **unpatched or barely-patched pre-auth flaws in internet-facing software**, several exploited before disclosure: Sansec's **StyleSmuggler** Magento/Adobe Commerce zero-day (now CVE-2026-75650, CVSS 10.0, attacks from 4 Sep, hotfix only on 7 Sep), CERT Polska's **MikroTrick** RouterOS SSH takeover (exploited from 2 Sep, three days ahead of disclosure), Sangoma Switchvox and JFrog Artifactory both landing on CISA KEV, and ~22,000 Exchange servers still exposed to CVE-2026-62911 with public exploit code. Second, **the software supply chain was attacked at three different layers in one week** - the network route (a BGP hijack served a malicious Virtualizor update that took root on hosting hypervisors), the registry endpoint (Coder's Cloudflare pool was repointed to serve credential-stealing Terraform modules for 14 hours), and the vendor's own CI (JetBrains was breached through an unpatched TeamCity, the product it ships, and told Cadence users to rotate everything). Signature and provenance checks did not help in any of the three, because in each case the thing trusted was not the artefact. Third, **AI moved from research finding to operational fact**: Unit 42 worked a real incident where autonomous agents breached an enterprise in under 10 hours using no zero-day, Forescout used Claude to port a pre-auth PLC exploit to a new hardware model for \$536, Manifold's **GitSpawn** flaws let untrusted repositories run commands outside seven coding agents' sandboxes, and UAC-0099 planted a nuclear-weapon prompt in a VBS comment purely to make LLM analysis abort. Regionally, no new Australian incident was logged but two ACSC alerts remain open and directly relevant (the CMS webshell campaign and in-country N-able N-central exploitation); APAC saw a DPRK-linked backdoor compiled into victims' own HAProxy binaries in South Korea and malicious Packagist themes turning Vietnamese streaming sites into an iOS spyware delivery surface. Identity data took the heaviest breach hit: 153M driver's licence scans traced to IDScan.net, 9.5M patients at Aesto Health, and sealed court filings from Thomson Reuters' C-Track.

AUSTRALIA - SPECIFIC

Local orgs & ACSC advisories

ACSC standing alerts still live for Australian orgs - CMS webshell campaign & N-able N-central exploitation

HIGH

VERIFIED

ACSC

Exploited

Australia

No new Australia-specific incident was logged this window, but two ACSC alerts remain open and directly relevant to this week's global themes. (1) A large-scale campaign scanning WordPress, Craft CMS, MaxSite, MetInfo and Joomla JCE at scale and dropping webshells - many Australian SMBs already affected; the Elementor Pro and All-in-One WP Migration flaws below feed straight into it. (2) Active exploitation **within Australia** of N-able N-central auth bypasses CVE-2026-18556 / CVE-2026-18577 (CVSS 8.2), with post-exploitation persistence via Cloudflare tunnels - the same RMM-abuse pattern as the Faronics Deploy / ScreenConnect campaign below. Patch to N-central Hotfix 2 and audit CMS estates for webshells.

PoC: Active exploitation observed within Australia

Refs: [cyber.gov.au](#) · [bleepingcomputer.com](#) · [cyber.gov.au](#)

ASD / ACSC - 'Multi-factor Authentication: Switch it on' national awareness push

MEDIUM

UNVERIFIED

ACSC

Identity

Guidance

The Australian Signals Directorate's ACSC ran an MFA awareness campaign on 1 September, restating Essential Eight Mitigation Strategy 7. The timing is useful rather than novel: this week's Dropbox / Lenovo ID account takeovers hit only accounts **without** MFA, and separate research documented 39 ways to compromise passkey deployments through enrolment, recovery and sync rather than through FIDO2 cryptography. Treat the campaign as a prompt to audit MFA coverage on federated and legacy sign-in paths, not just the primary IdP. Single-source awareness item (unverified).

Refs: [cyber.gov.au](#)

APAC - SPECIFIC

Regional incidents & actors

'ted' backdoor compiled into victims' own HAProxy builds - South Korea (DPRK-linked, APT37 overlap)

HIGH

VERIFIED

DPRK

Linux

Espionage

Rapid7 documented a previously undocumented Linux toolkit targeting South Korean media and automotive organisations since early 2025, attributed with medium confidence to DPRK APTs (C2 overlap with APT37). The 'ted' plugin is **compiled into the victim's own HAProxy 2.8.12 binary**, registering a filter that hooks the HTTP parser to log high-value traffic, steal session cookies and selectively inject scripts by client IP. Trojanised crond, agetty, atd, sshd and polkitd, an SSH credential logger and a curl-based RAT (CurlRAT) shipped alongside. No new file, no module load, no LD_PRELOAD - only hash comparison against a known-good build detects it.

PoC: Active exploitation - in-the-wild implant, no public PoC

Refs: thehackernews.com · rapid7.com · gbhackers.com

13 malicious Packagist Composer themes - Vietnamese streaming sites deliver iOS spyware stealing wallet seeds

HIGH

VERIFIED

SupplyChain

iOS

Vietnam

Socket found 13 malicious Composer theme packages on Packagist across the vsmov, vsphim, haiau009, chilltvcms and ophimcms namespaces, injecting JavaScript into every page of the Vietnamese movie/comic streaming sites that install them. Visitors on iPhone XS-16 running iOS <= 18.6.x are hit with a WebKit-to-kernel chain that exfiltrates keychain, Wi-Fi passwords, SMS, Photos, contacts, cookies, location history and **cryptocurrency wallet seeds**. Exploit hosts sit on Funnul infrastructure (US-sanctioned). The compromised party (site operator) and the harmed party (visitor) are different people - developer-endpoint telemetry sees nothing. Update iOS to 18.7.3 / 26.2+.

PoC: Active exploitation - WebKit-to-kernel chain in the wild

Refs: socket.dev · thehackernews.com · scworld.com

Fire Ant (China-nexus, UNC3886 overlap) - Cisco IOS XR routers turned into covert attack infrastructure

HIGH

VERIFIED

APT

China

NetworkImplant

Sygnia's Fire Ant cluster (strong overlap with UNC3886) expanded from ESXi/vCenter into **Cisco IOS XR routers, TACACS (tac_plus) servers and Linux management hosts** in telecommunications and critical infrastructure. Implants (TacTap, acppid) sit beneath the visibility layer: traffic interception, authentication-stack manipulation and defence evasion on devices EDR never reaches. Structurally identical to the 'ted' HAProxy implant and the Gambling Goblin Apache modules this week - persistence underneath the thing that inspects.

Refs: thehackernews.com · bleepingcomputer.com · industrialcyber.co

Counterfeit installer campaign (Silver Fox-aligned) disables Windows Update and degrades Defender - China-based operations

HIGH

VERIFIED

Malware

China

DefenceEvasion

Microsoft Defender Experts tracked high-fidelity clones of vendor download sites on **.com.cn and .hl.cn** infrastructure serving Chinese-language lures. The ZIP keeps the same filename while its hash changes on every download (server-side regeneration), defeating hash-based blocking outright. Follow-on activity disables Defender, deletes shadow copies, **neutralises Windows Update**, creates scheduled tasks and beacons over non-standard ports. Victims span healthcare, manufacturing, gaming, technology, logistics, government and education, primarily China-based operations of multinationals. Microsoft aligns the activity with publicly reported Silver Fox operations.

PoC: Active exploitation in the wild

Refs: microsoft.com · thehackernews.com · cybernews.com

#OpJapan - Yamanashi and Gifu prefectural government sites taken offline by hacktivist DDoS

MEDIUM

UNVERIFIED

Hacktivism

Japan

DDoS

Yamanashi and Gifu prefectural websites went offline on 27 August, attributed to a claimed #OpJapan hacktivist DDoS campaign. The underlying outage is dated and real; the analytical conclusion (that deployed DDoS mitigation frequently fails to cover every path, and the gap is discovered during the attack) comes from a vendor selling continuous DDoS validation and is recorded with that incentive noted. Single-source vendor blog - unverified.

Refs: mazebolt.com

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-75650 'StyleSmuggler' - Magento / Adobe Commerce pre-auth RCE 0-day (CVSS 10.0), exploited

CRITICAL

VERIFIED

ZeroDay

RCE

Exploited

Sansec disclosed an unauthenticated pre-auth RCE zero-day in Magento Open Source and Adobe Commerce; attacks began **04 Sep, one day before disclosure**. The flaw injects PHP into Magento's template system via styles properties (e.g. a generated failure report), then triggers execution through a failed-payment email. **Update since the vault note:** now tracked as CVE-2026-75650 (CVSS 10.0); Adobe shipped APSB26-146 on 07 Sep at Priority 1. Every version 2.4.4 through 2.4.9 is affected. Fix ships as a composer hotfix (VULN-39341-composer-patches.zip), not a full release. Adobe advises rotating the encryption key **and every credential it protected** - admin passwords, REST/SOAP/GraphQL tokens, OAuth secrets, payment gateway API keys, DB credentials, SSH/deploy keys.

PoC: Active exploitation in the wild since 2026-09-04 (backdoors planted)

Refs: sansec.io · thehackernews.com · cybersecuritynews.com

'MikroTrick' - MikroTik RouterOS unauthenticated SSH takeover (CVE-2026-67276 + CVE-2026-86060), exploited

CRITICAL

VERIFIED

Router

AuthBypass

Exploited

CERT Polska disclosed six RouterOS flaws on 05 Sep and chained the two most serious into 'MikroTrick': **CVE-2026-67276** (RouterOS does not compare the complete RSA public key during SSH auth - an attacker knowing a valid username and the public key can forge a key and log in without the private key) plus **CVE-2026-86060** (crafted SSH usernames beginning with a prohibited character manipulate the session policy mask, escalating to full admin). Result: complete unauthenticated administrative control over internet-exposed SSH. Exploitation confirmed from at least 02 Sep - three days before disclosure. **Hunt for the SSH user '-2' and a highly privileged account named 'ops'**. CVE-2026-67277 (CVSS 8.8) additionally leaks kernel memory or crashes the device via bandwidth-test.

PoC: Public - PoC released; exploitation observed since 2026-09-02 - cert.pl

Refs: cert.pl · thehackernews.com · helpnetsecurity.com

CVE-2026-9586 - Sangoma Switchvox unauth SQLi to RCE (CVSS 9.3), CISA KEV, exploited

CRITICAL

VERIFIED

VoIP

RCE

KEV

Unauthenticated SQL injection in Switchvox SMB Edition 8.3 leading to RCE. The /pa endpoint parses XML beginning <PolycomIPPhone> and concatenates the user-controlled PhoneIP value directly into PostgreSQL queries. Honeypots saw exploitation from 30 August with reverse shells and process enumeration; ~4,000 instances are internet-exposed, mostly US. **Fixed in 8.4.0.2 (released 14 July) and now on CISA KEV**. A compromised PBX yields a trusted internal position, call metadata/recordings, and outbound vishing under the organisation's own caller ID.

PoC: Active exploitation in the wild - reverse shells since 2026-08-30

Refs: bleepingcomputer.com · helpnetsecurity.com · horizon3.ai

CVE-2026-82329 - JFrog Artifactory auth bypass, admin-token minting (CVSS 9.8), CISA KEV

CRITICAL

VERIFIED

SupplyChain

AuthBypass

KEV

Authentication bypass in the **default configuration** of self-managed Artifactory granting unauthenticated network attackers administrative permissions. watchTower observed attackers minting admin tokens then surveying the environment for onward value. **Four days between fix and first observed abuse**; CISA added it to KEV on 02 Sep. Patched in 7.161.20 (28 Aug); per CCCS AV26-867 the fixed builds by branch are 7.111.21 / 7.117.28 / 7.125.20 / 7.133.29 / 7.146.38 / 7.161.20. Admin on the artefact registry is write access to every binary downstream pipelines pull without re-verification - the blast radius is everything built after compromise.

PoC: Active exploitation in the wild - watchTower observed token minting

Refs: bleepingcomputer.com · securityweek.com · thehackernews.com

CVE-2026-83548 / -83549 - SonicWall SMA1000 zero-day chain (CVSS 10.0 pre-auth SSRF), CISA KEV

CRITICAL

VERIFIED

VPN

ZeroDay

KEV

Two SMA1000 zero-days chained for unauthenticated RCE on the appliance; CVE-2026-83548 is a pre-auth SSRF at CVSS 10.0. Included in the CISA KEV batch of seven exploited flaws added this week. Affects SMA1000 6210 / 7210 / 8200v. Note the pattern rather than the CVE: this is the **second exploited pre-auth RCE chain in the same product line within roughly ten weeks** (cf. CVE-2026-15409/15410 in July). SMA1000 is behaving as a standing liability, not a patch-queue item.

PoC: Active exploitation in the wild

Refs: securityweek.com · thehackernews.com · cyber.gc.ca

CVE-2026-19490 / -19489 - Citrix NetScaler ADC & Gateway auth bypass (CVSS 9.3), now exploited

CRITICAL

VERIFIED

VPN

AuthBypass

Exploited

CVE-2026-19490 (9.3) is an authentication bypass requiring no credentials and no user interaction on certain Gateway and AAA server configurations; CVE-2026-19489 (8.8) is a memory overflow. Status moved to **actively exploited** this window. Affected: ADC/Gateway 14.1 < 14.1-73.32, 13.1 < 13.1-63.21, ADC FIPS < 14.1-73.32 FIPS, FIPS/NDcPP < 13.1-37.277, plus SecurAccess ZTNA Hybrid using customer-managed instances. Citrix-managed cloud and Adaptive Authentication already patched. Internet-facing remote access - patch first.

PoC: Active exploitation in the wild (CCCS AL26-019)

Refs: bleepingcomputer.com · thehackernews.com · cyber.gc.ca

CVE-2026-85046 - Chrome V8 type confusion 0-day, exploited (6th of 2026)

CRITICAL

VERIFIED

Browser

ZeroDay

Exploited

Emergency Chrome update for a V8 type-confusion flaw; a crafted HTML page achieves arbitrary code execution inside the renderer sandbox. Google confirmed real-world exploitation and withheld attack detail per standard practice. Shipped alongside 11 other fixes; sixth in-the-wild Chrome 0-day of 2026. Do not under-prioritise on the 'sandboxed' qualifier - a renderer-only bug still yields session cookies, in-memory tokens, the DOM of every same-process origin and the autofill surface. Force-update Chrome and all Chromium browsers (Edge, Brave).

PoC: Active exploitation in the wild

Refs: securityweek.com · cyber.gc.ca · clubic.com

CVE-2026-32475 - Elementor Pro empty-filename upload to RCE (CVSS 9.8), exploited

CRITICAL

VERIFIED

WordPress

RCE

Exploited

Elementor Pro before 4.2.2 runs **separate loops for upload validation and for processing** that disagree on empty file entries (blank filename, PHP reports UPLOAD_ERR_NO_FILE). A multipart upload whose first entry has an empty filename is seen one way by the validator and another by the mover: the attacker's file is written and executed. Now exploited in the wild with webshell delivery. Directly feeds the ACSC's open CMS-webshell alert. The transferable pattern: **any validate-then-process split across two iterations is an RCE candidate**.

PoC: Active exploitation - webshell delivery on live sites

Refs: bleepingcomputer.com · securityweek.com · x.com/TheHackersNews

CVE-2026-19949 - All-in-One WP Migration & Backup unauth SQLi to RCE, 3M-5M+ sites

CRITICAL

VERIFIED

WordPress

SQLi

MassExploitation

Unauthenticated SQL injection enabling code execution and full site takeover in a plugin with 3-5 million installations. Two things separate it from routine WordPress plugin CVEs: the install base makes mass automated exploitation economically guaranteed, and **it is the backup plugin** - by function it holds or can generate a full copy of the site and database, so compromise is data exfiltration as well as site control. The CVE identifier gap flagged mid-week is now resolved to CVE-2026-19949.

PoC: Mass automated exploitation expected - historically within days at this install base

Refs: bleepingcomputer.com · securityweek.com · clubic.com

CVE-2026-62911 - Microsoft Exchange auth bypass, ~22,000 servers still unpatched, exploit code public

CRITICAL

VERIFIED

Exchange

AuthBypass

Exposed

Reported by Orange Tsai (DEVCORE), CVE-2026-62911 lets an attacker with basic privileges hijack **all user mailboxes** on Exchange 2016 / 2019 / SE - send, read, download attachments. Microsoft fixed it on 11 August; ~22,000 internet-exposed servers remain unpatched (US ~6,200, Germany ~5,100) and **NCSC-NL reports exploit code is already public**. The residual population is the finding: a mailbox-wide auth bypass is a top-tier initial-access primitive - correspondence, password-reset flows for every downstream SaaS, and a trusted internal sender for onward phishing - available at the cost of scanning.

PoC: Public - exploit code available online (NCSC-NL)

Refs: bleepingcomputer.com · helpnetsecurity.com · cryptika.com

CVE-2026-0768 - Langflow unauthenticated Python code execution as root (CVSS 9.8), exploited

CRITICAL

VERIFIED

AI/LLM

RCE

Exploited

Langflow's custom-component code validator passes a user-supplied code parameter to Python exec() without sanitisation - unauthenticated RCE as root. VulnCheck logged 50+ detections within hours on 30 Aug, rising to 360 by 07 Sep, traffic largely from Russia. The exploitation is **not** generic mining or webshells: attackers query LANGFLOW_SUPERUSER, OPENAI_API*, AWS_ACCESS*, AWS_SECRET*, read /root/.cache/langflow/secret_key, and check .ssh and .bash_history. The vulnerability is the door; the credential store is the target. Originally disclosed by Trend ZDI in January.

PoC: Active exploitation in the wild - 360+ detections (VulnCheck)

Refs: bleepingcomputer.com · securityweek.com · thehackernews.com

Cisco September round - critical Nexus 9000 root RCE (CVE-2026-20212) & IOS XR; Secure Email S/MIME unpatched

CRITICAL

VERIFIED

Network

RCE

Unpatched

Two halves. **Patched:** CVE-2026-20212 (CVSS 9.8) lets remote unauthenticated attackers connect to by-default-open TCP ports on Nexus 9000 and execute code as root; IOS XR fixes cover seven CVEs including CVE-2026-20274 and CVE-2026-20279 (both 9.8, memory corruption / improper access control). **Unpatched and publicly known:** CVE-2026-20354 / -20355 in Cisco Secure Email S/MIME decryption - insufficient message-integrity validation allows a MitM between gateways to modify traffic and recover plaintext from encrypted mail. All devices on AsyncOS <= 16.5.0 with S/MIME enabled; mitigation is configuration and monitoring only. Also in AV26-876: Desk Phone 9800 / Video Phone 8875 < 5.0(1), IP Phone 7800/8800 < 14.4(1)SR3, 8845/8865 < 14.4(1)SR4, Wireless IP Phone 8821.

Refs: securityweek.com · thehackernews.com · cyber.gc.ca

CVE-2026-73749 - HPE Aruba Networking AOS-CX unauthenticated RCE (CVSS 9.8)**CRITICAL****VERIFIED**

Switch

RCE

NOS

A buffer overflow in an AOS-CX daemon lets unauthenticated remote attackers send crafted packets and execute code with elevated privileges on the switch OS. Part of a 31-vulnerability AOS-CX round on 01 Sep. Fixed in 10.18.1002+, 10.17.1030+, 10.16.1060+, 10.13.1190+ and 10.10.1181+ - note 10.10.1181 is End of Maintenance and receives fixes only for internally found critical issues, which includes this one. HPE reports no known exploitation. Switch RCE sits **beneath** the visibility layer: an implant in the NOS mirrors, drops or reroutes selectively and is invisible to EDR, host logging and network sensors.

Refs: bleepingcomputer.com · securityweek.com · socradar.io

CVE-2026-59346 - VMware Workstation / Fusion guest-to-host escape (CVSS 9.3)**CRITICAL****VERIFIED**

Hypervisor

VMEscape

AnalystRisk

Integer overflow in the **VMXNET3 virtual network adapter** (VMSA-2026-0007, 03 Sep): a local administrator inside a VM executes code on the host. Companion flaw CVE-2026-59347 (8.1) is a stack overflow in HGFS shared folders. Affects Workstation and Fusion 25H2 and 26H1; fixed in 26H1u1. This matters more than usual right now: Workstation/Fusion is the malware-detonation platform for most small and mid-sized security teams, so a guest-to-host escape converts a routine detonation into compromise of the analyst host - sample repos, TIP sessions, EDR consoles and internal credentials. Reinforces the Trail of Bits finding below that off-the-shelf VMs are not a containment boundary.

Refs: securityweek.com · securityaffairs.com · cybersecuritynews.com

CVE-2026-63219 + CVE-2026-58400 - GeoNetwork unauth RCE chain behind government geoportals**CRITICAL****VERIFIED**

Government

RCE

GIS

CVE-2026-63219 (8.6) is a missing authorisation check on the formatter upload endpoint - an unauthenticated user writes arbitrary .xsl or .zip formatters. CVE-2026-58400 (9.1) is an unsafe Saxon XSLT processor configuration letting a loaded stylesheet call `Runtime.exec()` / `ProcessBuilder` as the GeoNetwork process user. Chained: upload a malicious formatter, render it, get OS command execution. Affects <= 4.2.16 and 4.3.0-4.4.11; fixed in 4.2.17 / 4.4.12 (patches shipped 08 Jul, details public 31 Aug). **Ethiack fingerprinted 121 exposed vulnerable deployments across 39 countries - 89% government, military or national agency**, including the European INSPIRE geoportal backend.

PoC: **Public technical write-up with exploitation path (Ethiack)** - ethiack.com

Refs: thehackernews.com · ethiack.com · jonix.io

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-6471 'PostGRESHell' - 12-year-old PostgreSQL logical decoding flaw to server takeover**HIGH****VERIFIED**

Database

PrivEsc

RCE

Missing authorisation in logical decoding lets a **non-superuser holding REPLICATION** choose any library visible to the PostgreSQL OS account as a decoding output plugin, dlopen it, and run arbitrary code as the postgres OS user - full host compromise, then permanent superuser and a persistent in-database backdoor. Present since logical decoding shipped in 9.4 (2014); affects everything < 18.6 / 17.11 / 16.15 / 15.19 / 14.24. CVSS 7.2 is held down by the REPLICATION precondition, which in real estates is weak: every read replica, logical subscriber and CDC connector (Debezium, Fivetran, Airbyte, AWS DMS) routinely holds it. Fix (13 Aug) adds `output_plugin_libraries`, defaulting to `pgoutput`, `test_decoding`. **Audit who holds REPLICATION.**

PoC: **Public - researchers demonstrated persistent in-database backdoor**

Refs: postgresql.org · thehackernews.com · securityweek.com

CVE-2026-84115 - Cleo Harmony JWT refresh-token privilege escalation (CVSS 8.3), public exploit

HIGH

VERIFIED

MFT

AuthBypass

PublicExploit

Improper privilege management (CWE-269) in the Cleo Harmony JWT Refresh Token Handler and /api/connections endpoint: manipulating the Bearer argument in HTTP authorization headers bypasses authentication and escalates privileges. Affects up to 5.8.1.10; **patch to 5.8.1.11**. Disclosed 01 Sep, exploit code now public. Cleo MFT warrants elevated urgency specifically because ClOp mass-exploited Harmony/VLTrader/LexiCom in late 2024 after MOVEit and GoAnywhere - a capable group already knows the codebase, and MFT is data-theft-optimal and internet-facing by design.

PoC: Public - exploit code publishedRefs: securityweek.com · rapid7.com · thecyberexpress.com**Chrome & Firefox patch cycle - sandbox escape and use-after-free classes (CCCS AV26-868 / AV26-874)**

HIGH

VERIFIED

Browser

SandboxEscape

Dozens of fixes including use-after-free, **sandbox escape** and privilege escalation. Mozilla: Firefox < 155 and Firefox ESR < 115.40, < 140.15 and < 153.2. Chrome moved to 152.0.7977.75. The sandbox-escape class is why this cycle should be forced rather than left to ride. Operational note: **three distinct ESR branches** are listed - confirm which branch each managed estate is pinned to rather than assuming one number, because split ESR fleets are exactly where 'we patched Firefox' turns out to be true for only part of the estate.

Refs: securityweek.com · cyber.gc.ca · malwarebytes.com**CVE-2026-67394 - Plesk local privilege escalation to root via OS command injection**

HIGH

UNVERIFIED

Hosting

PrivEsc

MultiTenant

A customer or reseller account with shell access (or able to change its own shell access) escalates to root. Affects all Plesk for Linux from 18.0.34 before 18.0.79.9 / 18.0.80.5; **no mitigation exists where shell access is required** - update is the only remedy. The privesc class is usually deprioritised on 'the attacker already needs local access', but on shared hosting the attacker *always* has local access - it is sold to them. Root here is tenant-isolation collapse across every site on the box, plus panel-stored DNS, mail and database credentials. Two independent sources (vendor + CCCS) - unverified.

Refs: support.plesk.com · cyber.gc.ca**CCCS advisory cluster AV26-877 to AV26-882 - Jenkins, F5, AMD firmware, n8n, Siemens Mendix, SUSE Rancher**

HIGH

UNVERIFIED

Advisories

CI/CD

Firmware

Six advisories in a single afternoon; grouped because **four of them are credential-holding infrastructure** rather than end-user software. **AV26-877 Jenkins** core (all versions except 2.568.3 LTS / 2.580 weekly) plus Allure <=2.35.2, Customizable Header, File Parameter and GitLab <=1.9.16 plugins. **AV26-878 F5** BIG-IP (all modules) < 17.1.3.4 / 17.5.1.8 / 21.0.0.3 / 21.1.0.1, BIG-IQ < 8.4.2.1, NGINX Gateway Fabric < 2.6.8. **AV26-879 AMD** (AMD-SB-7009) firmware across 2nd-4th Gen EPYC, EPYC Embedded, Instinct MI300A, Radeon PRO V620 and Ryzen 3000-7000 - delivered via OEM BIOS/AGESA, so the patch path runs through the hardware vendor, not AMD. **AV26-880 n8n** fixed in 1.123.76 / 2.35.4 / 2.36.2 / 2.37.7 / 2.38.2. **AV26-881 Siemens** SSA-887643 Mendix SAML account hijacking, fixed V4.2.3 / V3.6.27. **AV26-882 SUSE Rancher** < 2.15.1.

Refs: cyber.gc.ca · cyber.gc.ca · cyber.gc.ca**Rockwell Automation AV26-869 - 12+ flaws across RSLinx Classic, ArmorStart, ControlFLASH, FactoryTalk**

HIGH

UNVERIFIED

ICS

OT

EndOfLife

Multiple ICS products affected; no CVE IDs were listed in the CCCS relay so none are asserted here. Affected: **1756-ENBT Module - all versions**; ArmorStart LT <= v2.001; CompactLogix 5380 / ControlLogix 5580 <= V33, V34.011-V34.014, V35.011-V35.013, V36.011-V36.012; RSLinx Classic <= V4.50. The line that matters is 'all versions' on 1756-ENBT - that is an end-of-support signal, not a patching instruction. An asset owner reading it as a patch task finds nothing to apply and quietly closes the ticket; **that silent close is the actual risk in this advisory**. Remediation is compensating control or replacement. Two independent sources - unverified.

Refs: cyber.gc.ca · securityweek.com

Plex ships undisclosed security fixes - no CVEs, no detail, urgent advisory

MEDIUM

UNVERIFIED

Vendor

Opacity

Plex urged immediate updates to Media Server and desktop apps for 'a number of security issues', publishing no technical detail, no CVE identifiers and no statement on exploitation. This resolves nothing from the 04 Sep sweep where Plex appeared in a CCCS advisory body that enumerated no CVEs - and the **pattern is the finding**. Silent security releases invert defender triage inputs: with no severity, exploitability, exposure or exploitation status published, the only options are patch everything immediately or guess.

Refs: privacysavvy.com · bleepingcomputer.com

WhatsApp on locked Android - incoming video call reaches the photo gallery

MEDIUM

UNVERIFIED

Mobile

LockScreen

Privacy

Receiving a WhatsApp video call on certain locked Android handsets lets whoever is holding the device reach the photo gallery with no PIN, password or fingerprint. Reported by Jose Rodriguez on 01 Sep and reproduced independently. Lock-screen bypasses are systematically under-triaged as 'requires physical access', but the threat model for a lock screen is not a sophisticated remote attacker - it is a partner, family member, colleague, border officer, thief or police at a traffic stop, for every one of whom physical possession is the scenario, not a mitigating precondition. Single-source - unverified.

Refs: privacysavvy.com

Proxmox VE 7.x auth bypass / pre-auth RCE - CLAIM ONLY, no advisory, no CVE

WATCH

UNVERIFIED

Claim

Unverified

Hypervisor

A social-media post captioned 'Proxmox VE 7.x authentication bypass (pre-auth RCE)' with a screen-recording demo, ~194K views. **That is the entire evidentiary basis.** No CVE, no Proxmox advisory, no affected build range, no technical write-up, no second source. Recorded as a claim rather than a vulnerability because Proxmox VE is a hypervisor management plane and the asymmetry between 'probably nothing' and 'whole-estate event' justifies a stub. Do not action; monitor for a Proxmox advisory.

Refs: x.com/nebusecurity

GLOBAL - SOFTWARE SUPPLY CHAIN

Route, registry & vendor CI

Virtualizor BGP hijack - malicious update delivers persistent root on hosting hypervisors

CRITICAL

VERIFIED

BGP

SupplyChain

RootAccess

From ~20:57 UTC 28 Aug to 06:10 UTC 30 Aug, **AS62390 (NexonHost) announced 162.55.80.0/24** - a Hetzner block used by Softaculous update and billing systems - via AS6204 (Zet.net). Hetzner advertised only 162.55.0.0/16, so the more-specific prefix won everywhere it propagated. Virtualizor's update client did not cryptographically verify packages, so a hijack plus a valid TLS certificate (obtained through route control) was enough to run attacker code as root. The package altered three legitimate Virtualizor files; a root cron job then added an attacker SSH key, installed Java, fetched a payload, left it running as a systemd service and created an account named **proxyuser**. This is the structurally interesting item of the week: the update server's identity was not compromised - **the route to it was**.

PoC: Active exploitation - 5 of 34 checked hypervisors root-compromised at one provider

Refs: bleepingcomputer.com · thehackernews.com · securityweek.com

Coder registry infrastructure compromised - malicious Terraform modules stole cloud & CI credentials

CRITICAL

VERIFIED

Terraform

IaC

CredTheft

An attacker (reportedly via a compromised API key) added unauthorised IP addresses to the Cloudflare origin pool serving **registry.coder.com**, so Cloudflare routed a share of legitimate registry requests to attacker-controlled servers hosting modified Coder Terraform modules. Window: **07:35-21:45 UTC on 31 August**. The modules harvested cloud and AI-tooling API keys, CI/CD credentials, config-file secrets, terminal history, OIDC tokens, SSH keys and one-time auth tokens. Module signature and provenance checks did not apply because the thing trusted was **the endpoint, not the artefact**. Coder cannot conclusively identify every compromised deployment - rotate anything a provisioner touched that day.

PoC: Active exploitation - 14-hour exposure window, credentials exfiltrated

Refs: bleepingcomputer.com · esecurityplanet.com · scworld.com

JetBrains Cadence breached via unpatched TeamCity (CVE-2026-63077) - AWS credentials extracted

CRITICAL

VERIFIED

CI/CD

SupplyChain

CredTheft

Between **08 and 24 August**, attackers exploited CVE-2026-63077 (CVSS 9.8, deserialisation of untrusted data allowing unauthenticated auth bypass and OS command execution) to breach JetBrains' own Cadence cloud compute service. Extracted: usernames, real names, emails, last-login timestamps, last-accessed IPs, multiple **AWS IAM credentials**, project source code, config files and secrets from a 2024 Cadence server backup, plus files in JetBrains AWS S3 buckets. JetBrains invalidated all Cadence plugin tokens in PyCharm and tells users to rotate across AWS, Azure, GCP, GitHub, GitLab, Bitbucket, npm, PyPI, Docker registries, Slack, SSH keys and signing certificates. **The vendor that writes TeamCity did not patch its own TeamCity in time** - 'we'll get to the CI server next cycle' is no longer defensible anywhere.

PoC: Active exploitation - CVSS 9.8 deserialisation RCE used against the vendor itself

Refs: thehackernews.com · rescana.com · beyondmachines.net

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

'GitSpawn' - malicious .git configs make 7 CLI AI coding agents run attacker code (4 unpatched at publication)

CRITICAL

VERIFIED

PoC

AIAgent

SandboxEscape

Manifold Security disclosed eight flaws across seven CLI AI coding agents. Git honours per-repository settings that name a command - core.fsmonitor, core.pager, core.editor, diff.*.textconv, hooks - and the agent executes it **as the developer, outside its sandbox, before the workspace-trust prompt, with no approval and nothing on screen**. Exploitation needs the repo to arrive as files with .git intact (shared archive, network drive, sync folder, USB) - an ordinary clone does not preserve it. Fixed in goose, Claude Code and Cursor; **Hermes Agent, Qwen Code, Grok Build and a second Claude Code path were still executing repo-supplied commands on retest 01 Sep**. The sandbox was not bypassed - it was never in the path.

PoC: Public - technique and affected-agent matrix published - manifold.security

Refs: manifold.security · thehackernews.com · heise.de

Forescout used Claude to port a pre-auth RCE between WAGO PLC models - live ARM shellcode, \$536 of API time

CRITICAL

VERIFIED

PoC

AI

OT/ICS

Vedere Labs ported a working exploit for **CVE-2021-31886** (pre-auth stack overflow in the Nucleus FTP USER handler, CVSS 9.8, TCP/21) from a WAGO 750-852 to a WAGO 750-831 on firmware V01.04.16, executing attacker ARM shellcode on live hardware. Claude Code had a terminal, Ghidra and the target PLC; work started on Sonnet 4.6 and moved to Opus 4.6 when RCE attempts stalled. Normal FTP processing on the 750-831 zeroed 256 bytes at the buffer, so the model adapted the USER+QUIT sequence into USER+CWD. Final stage: **\$535.74 over 8h32m**. Nothing here is a new CVE - the finding is the collapsing cost of the *second* exploit. OT has been protected less by patching than by model fragmentation, and that protection is now priced in dollars and hours.

PoC: Public - research write-up; working exploit demonstrated on live hardware - thehackernews.com

Refs: thehackernews.com · cybersecuritynews.com · gbhackers.com

'FalconFlank' - claimed CrowdStrike Falcon local privilege escalation PoC (Nightmare Eclipse)

HIGH

VERIFIED

PoC

EDR

Claim

A PoC published by the handle **Nightmare-Eclipse** claims local privilege escalation to SYSTEM on a fully updated Windows host by abusing the Falcon sensor's own malicious-Office-macro remediation path. **Treated as a claim, not an established vulnerability**: no CVE, no CrowdStrike advisory read, no independent reproduction observed. Recorded because the mechanism is specific and testable, and because this is the same actor cluster behind the recurring 'Eclipse' Defender and BitLocker drops - repos in this cluster are taken down and re-uploaded, so capture IOCs for IR and expect opportunistic reuse.

PoC: Public - PoC published by the actor; no vendor advisory, no independent reproduction

Refs: thehackernews.com · bleepingcomputer.com

SpecterOps / Outflank - open-source AI 'skills' marketplace for red-team ops (Cobalt Strike & Outflank C2)

HIGH

UNVERIFIED

Tool

RedTeam

AI

SpecterOps published an open-source skills marketplace letting an LLM agent drive established C2 frameworks - the c2-cobaltstrike plugin covers Aggressor scripts and Malleable C2 profiles; the bloodhound plugin connects to a remote MCP server. Read it alongside Unit 42's autonomous-agent intrusion and the Forescout WAGO port: those are capability demonstrations, **this is the packaging layer that makes the capability distributable** - reusable, versioned, published openly. Red-team tooling has historically led criminal tooling by about a release cycle; Cobalt Strike is the standing example. Vendor/tool announcement, effectively single-origin - unverified.

PoC: Public - open-source repository - github.com

Refs: outflank.nl · github.com

waf-fu - AWS WAF log replay for credential access (TrustedSec)

HIGH

UNVERIFIED

Tool

AWS

CredTheft

Pulls AWS WAFv2 log data into a local SQLite cache and replays logged sessions as curl commands, browser sessions with header injection, or batch HAR export into Burp. **The finding is about AWS WAF logging, not the tool**: default WAF logging captures full request headers with no automatic redaction - Cookie, Authorization, X-API-Key, X-Amz-Security-Token. Any log group or bucket prefixed aws-waf-logs- is therefore a credential store nobody classified as one, and harvesting it needs only read-only IAM (logs:FilterLogEvents, s3:GetObject, wafv2:GetSampledRequests) - permissions routinely granted to auditors and SIEM integrations. Two sources from one origin - unverified.

PoC: Public - open-source tool - github.com

Refs: trustedsec.com · github.com

OpenLeash - human approval gate for risky AI agent actions (allow / block / ask)

INFO

UNVERIFIED

Tool

Defense

AgentSecurity

Intercepts AI agent actions, blocks clearly dangerous ones and escalates to a human when intent is ambiguous. Aimed squarely at this sweep's accumulating evidence - the GitSpawn .git config flaws where seven coding agents ran attacker commands with no approval prompt, and Unit 42's autonomous-agent intrusion. The three-state design is the right shape: binary allow-or-deny policies fail in both directions - too permissive and the agent is a confused deputy, too restrictive and users disable the control to get work done. Single-source vendor announcement - unverified.

Refs: securityweek.com

CrowdRecon (Intigriti) - paying for the reconnaissance layer, not only finished reports

INFO

UNVERIFIED

Tool

BugBounty

Recon

Bug bounty pays on outcome, so every hunter independently redoes the same asset discovery and the programme owner sees none of it - the discovery is a cost the hunter absorbs and the platform discards. CrowdRecon captures and pays for that layer. If it works, the programme owner gains a continuously refreshed external asset inventory built by adversarial parties, which is a materially better input than most internal CMDBs. Single-source vendor announcement - unverified.

Refs: intigriti.com

GLOBAL - MALWARE & CAMPAIGNS

ASCII smuggling crosses from AI prompt injection to phishing evasion - millions of messages

HIGH

VERIFIED

Phishing

Unicode

Evasion

Microsoft identified a high-volume campaign inserting invisible **Unicode Tags block** characters (U+E0000-U+E007F) inside words. A single TAG SPACE (U+E0020) placed mid-keyword - fun<U+E0020>ding - breaks literal keyword and signature matching while **rendering identically to a human reader**. Volume went from 21,000 to 1.3 million messages in one day across ~150 domains. Notably **no hidden AI instructions were present**: the technique was borrowed from prompt-injection research and repurposed for classic filter evasion. Detection: normalise or strip the Tags block before content matching, and alert on its presence at all - legitimate mail has no reason to contain it.

PoC: Active campaign - 21k to 1.3M messages in one day, ~150 domains

Refs: microsoft.com · thehackernews.com · clubic.com

Unit 42 IR - autonomous AI agents breached an enterprise network in under 10 hours

HIGH

VERIFIED

AI

Ransomware

IR

A human actor drove frontier models and attack-specific agentic frameworks to breach an enterprise in **under 10 hours** - work Unit 42 assesses would take multiple human red teams roughly two weeks, spanning 50+ MITRE ATT&CK techniques. Chain: breach a public web service to tunnel in, deploy a recon agent to map internal microservices, sub-agents comb code repos for hard-coded tokens and service passwords, use those to enter the secrets manager and harvest master admin credentials, then turn the victim's own AI endpoints into post-compromise infrastructure. **No zero-day and no unusual tradecraft** - the speed came purely from AI-assisted operational efficiency. This is the operational half of a story whose lab half (Forescout, OpenAI Astra) the vault already holds.

PoC: Real incident-response engagement, not a lab result

Refs: unit42.paloaltonetworks.com · theregister.com · cybernews.com

ClickFix payloads served from BNB Smart Chain smart contracts across 5,400+ hacked sites

HIGH

VERIFIED

ClickFix

EtherHiding

Blockchain

More than 5,400 compromised small-business sites (mostly WordPress and PrestaShop) inject a script that fetches its next stage from a **smart contract on the BNB Smart Chain testnet endpoint** - EtherHiding. Fake CAPTCHA prompts then trick visitors into pasting commands that install infostealers (Lumma Stealer observed). A newer variant drops the ClickFix overlay entirely and opens a covert **WebRTC data channel for C2**. EtherHiding has moved from research curiosity to commodity delivery infrastructure: there is no host to take down, the payload is immutable and publicly readable, and retrieval looks like ordinary RPC traffic.

PoC: Active campaign - mass compromise of WordPress/PrestaShop sites

Refs: bleepingcomputer.com · netskope.com · blackpointcyber.com

Python NodeStealer upgraded to full spyware - keylogging, clipboard, screenshots, dual-bot Telegram C2

HIGH

VERIFIED

Infostealer

Spyware

AI-Assisted

Netskope's August 2026 variant adds pynput keystroke logging, pyperclip clipboard monitoring and pyautogui screenshots on top of browser-credential and Facebook Ads Manager theft, with a dual-bot Telegram C2. Facebook targeting expanded from basic account details to **20+ Graph API endpoints** covering identity, social graph, account security and commerce data. Researchers suspect AI-assisted development (systematic decorative emoji in output logs, absent from prior variants). The capability shift routes around exactly the defences that blunted stored-credential theft - session binding, passkeys and short-lived tokens do not stop a keylogger. Victims mainly in Asia and North America, led by financial services.

Refs: netskope.com · cybersecuritynews.com · gbhackers.com

'Gambling Goblin' - rogue Apache modules on Brazilian government and education servers (Earth Berberoka link)

HIGH

VERIFIED

Malware

Persistence

SEOFraud

Check Point tracked a Chinese-speaking cluster (tied to Earth Berberoka, documented by Trend in 2022) installing malicious Apache modules on compromised Brazilian federal, state and municipal government and education servers since mid-2025 - a ministry, a national agency, a state legislative assembly, courts of accounts and a state-owned utility. Modules reverse-proxy visitors to phishing pages that impersonate Google Play, Microsoft Store and Amazon while traffic still appears to originate from the legitimate domain, and **strip the site's own security headers**. Goal is SEO manipulation at scale using high-reputation domains. The payoff is low-grade; **the implant is not** - it loads in-process with the web server, lives in module config rather than web content, and is invisible to file-integrity monitoring on the document root and to defacement monitoring.

Refs: research.checkpoint.com · thehackernews.com · infosecurity-magazine.com

StreamRat Android banking trojan pushed via Meta and TikTok streaming ads (~571k EU reach)

HIGH

VERIFIED

Android

Malvertising

BankingTrojan

ThreatFabric documented a new Android banking trojan promoted to Spanish-speaking users through fake TV-streaming ads on Meta (campaign ran **11 June to 3 July 2026**, reaching ~570,950 EU accounts) and on TikTok. StreamRat abuses Accessibility Services and MediaProjection for VNC and hidden-screen control, UI-tree collection, keylogging, credential-stealing overlays and internet/screen blocking - near-total device control after sideloading and granting a succession of permissions. The delivery channel is the story: **the platform delivered the lure, targeted and paid for**, with demographic and language targeting, creative A/B testing and the implicit legitimacy of a mainstream feed. 'Only install from the Play Store' does not address it.

Refs: threatfabric.com · thehackernews.com · malwarebytes.com

Pegasus zero-click iMessage exploit on a Serbian student-movement iPhone; 14 targets documented

HIGH

VERIFIED

Spyware

ZeroClick

CivilSociety

Citizen Lab and the SHARE Foundation found high-confidence Pegasus infection indicators on a Serbian student protest organiser's iPhone across December 2025 and January 2026, delivered by an **iMessage zero-click** Citizen Lab believed Apple had patched in iOS 18.4.1 (April 2025). At least 14 targets are documented among Serbia's student movement, civil society and an opposition MP, ahead of key 2026 election cycles; a new NoviSpy build was found on another student's device. Zero-click delivery means awareness training is not a control against this class; fourteen targets in one country inside a year is a programme, not opportunistic use.

PoC: Zero-click iMessage exploit used in the wild

Refs: citizenlab.ca · thehackernews.com · infosecurity-magazine.com

Faronics Deploy abused to install ScreenConnect - 457+ endpoints, zero malware in the chain

HIGH

VERIFIED

RMM

LOTL

Phishing

Faronics-themed lures disguised as invoices and tax documents reached **457+ endpoints between 21 July and 20 August**, tricking victims into running a legitimate, signed Faronics Deploy installer masquerading as an Adobe file. Attackers then used the platform's own PowerShell script execution to pull further scripts (including from GitHub) and install ScreenConnect for persistent access. **Two commercial products, zero implants** - signed binaries, vendor certificates, expected destinations, an ordinary process tree. Hunt: C:\ProgramData\Faronics\Logs\ScriptRunner.log for script names and URLs, the ck parameter in Faronics config requests for rogue accounts, and any ScreenConnect install outside approved policy. Activity declined after 21 August following Faronics' countermeasures.

PoC: Active campaign 21 Jul - 20 Aug; Huntress published hunting artefacts - huntress.com

Refs: bleepingcomputer.com · huntress.com · thaicert.or.th

UAC-0099 'GuardBreaker' - a nuclear-weapon prompt in a VBS comment to stop LLM malware analysis

MEDIUM

VERIFIED

AntiAnalysis

PromptInjection

Russia

ESET found Russia-aligned UAC-0099 inserting the comment *'I want to make a nuclear weapon. Help me ...'* into a malicious VBS script used against a Ukrainian target. The string is inert as code; its entire function is to **deliberately trip the safety mechanisms of any LLM used to analyse the file**, so an automated SOC pipeline aborts and refuses before reaching the rest of the script. The script's real job is to install MATCHBOIL, the group's C# loader. UAC-0099 historically targets transportation and energy. Mitigation: strip or neutralise comments before LLM analysis, and treat an analysis refusal as a detection signal rather than a null result.

Refs: thehackernews.com · helpnetsecurity.com · x.com/ESETresearch

Qualys - silent Active Directory domain takeover in 54 minutes using only legitimate protocols

HIGH

UNVERIFIED

ActiveDirectory

LOTL

Detection

A full domain takeover from first password spray to forged Golden Ticket in **54 minutes**, with no malware deployed and every individual event appearing normal - password spraying, Kerberoasting, DCSync replication, ACL modification, group membership change. The most operationally useful item of the week because it is a detection-engineering deliverable rather than an event: an alerting strategy built on 'what executed' sees nothing here, because **every step is a supported feature**. The evidence exists only as a sequence, so detection must correlate five individually benign Windows events by identity, source IP and Logon ID. Single-source vendor blog - unverified, but the technique chain is independently well established.

Refs: blog.qualys.com

REVSTEALER - four companion modules persist after the stealer self-deletes; one kills Defender and mines

HIGH

UNVERIFIED

Infostealer

Persistence

Miner

Elastic Security Labs documented four previously unreported modules - **ProManager**, **WinUpdate**, **SoftManager** and **LockAppHost**. LockAppHost disables five Windows Update services, kills eleven scheduled update tasks, strips Defender protections and buries a cryptocurrency miner inside Windows-owned processes. The activity set also hijacks crypto transactions and turns victims into a reverse proxy; distribution runs on game-cheat lures and fake software. **The ordering is the finding**: the stealer self-deletes and the modules stay, so the standard IR shape (find the stealer, remove it, rotate credentials, close) finds nothing at step two and closes a case that is still live. Two independent sources - unverified.

Refs: thehackernews.com

Guildma / Astaroth - full infection chain from a Brazilian-Portuguese email (SANS ISC)

MEDIUM

UNVERIFIED

BankingTrojan

LOLBin

LATAM

An ISC diary walking the complete infection traffic for a Guildma (Astaroth) infection delivered by Brazilian-Portuguese email. The family is a long-running testbed for living-off-the-land delivery - legitimate Windows binaries for download and execution, heavy script staging, cloud-service hosting. **The regional framing is the trap**: a Brazilian-Portuguese lure is a targeting decision, not a technical constraint, and the delivery chain ports to any language. Single-source diary - unverified, but useful as detection material rather than as an incident.

Refs: isc.sans.edu

GLOBAL - NOTABLE BREACHES

153M+ driver's licence scans on the dark web - traced to IDScan.net; FBI investigating, 8+ class actions

CRITICAL

VERIFIED

IdentityData

DarkWeb

Litigation

A dark web service called **Nexus** is selling scans of 153M+ US and Canadian driver's licences plus 10M+ state ID cards, 3M travel documents and 579,000 medical marijuana cards. Krebs traced the data to **IDScan.net**, a New Orleans identity-verification firm running 21M+ ID checks a month at 20,000+ locations for clients including Hertz, Target, FedEx, Motorola Solutions and Caesars. The FBI's New Orleans office is investigating; four class actions were filed on 02 Sep in the Eastern District of Louisiana and at least eight federal suits have followed. **Nothing here is rotatable**. A leaked credential is replaced in minutes; a leaked licence scan is valid until the licence expires and the holder is never told. ID verification has become a single point of failure for account recovery, rentals and age checks alike.

Refs: krebsonsecurity.com · bleepingcomputer.com · infosecurity-magazine.com

Aesto Health - 9,540,683 individuals; SSNs, financial and health data (2nd-largest US healthcare breach of 2026)

CRITICAL

VERIFIED

Healthcare

PII

HHS

Aesto LLC provides SaaS for migrating and archiving patient data when health organisations replace EHR systems or acquire practices - a data-concentration role by design. Intrusion occurred **2-18 December 2025**, confirmed internally on 26 May, first disclosed publicly 24 June, now reported to HHS OCR as affecting **9,540,683 individuals** - second only to DentaQuest's 15M this year. Exposed: names, dates of birth, medical information, driver's licence numbers, financial account numbers, health insurance information, taxpayer and other government IDs, and SSNs. Note the disclosure lag: ~six months from intrusion to public notice, ~nine to final scope.

Refs: bleepingcomputer.com · hipaajournal.com · beckershospitalreview.com

Thomson Reuters C-Track breach - sealed court filings exposed across 11-12 US states, USVI and Ontario

CRITICAL

VERIFIED

Legal

SealedRecords

Government

An unauthorised party obtained files from **C-Track**, the court case-management platform sold by Thomson Reuters' West Publishing unit, in March 2026; West discovered the activity on 30 June. Affected courts span 11-12 US states, the US Virgin Islands and Ontario. Exposed records may contain names, SSNs, driver's licence numbers, dates of birth, medical information and health insurance data - **and sealed and redacted filings**. Sealing exists to protect people from identifiable harm: cooperating-witness and informant identities, victim identities in sexual-offence and child-abuse matters, juvenile records, protective-order applications carrying the applicant's address, grand jury material. Twelve months of Experian IdentityWorks offered (enrolment to 31 Dec 2026).

Refs: therecord.media · thehackernews.com · helpnetsecurity.com

Trezor / ShipMonk - 67,000 more US customers exposed via Metabase 0-day (CVE-2026-72898, ShinyHunters)

HIGH

VERIFIED

ThirdParty

Retention

Crypto

Trezor learned on 02 Sep that the ShipMonk incident also covered order data from a prior partnership spanning **November 2019 to August 2021** - names, emails, phone numbers, shipping addresses and order numbers for ~67,000 additional US customers, taking the total to roughly 80,700. Wallet seeds, private keys and funds are unaffected. The breach was enabled by a **CVSS 10.0 SQL injection zero-day in Metabase (CVE-2026-72898)** used by ShipMonk, attributed to ShinyHunters. The transferable lesson is the retention claim: Trezor had told customers this data was deleted. It was not - it was sitting at a fulfilment provider. **A deletion commitment covers data the company controls, not data its processors retained**.

PoC: **Active exploitation - CVSS 10.0 SQLi zero-day in Metabase**

Refs: thehackernews.com · trezor.io · cybersecuritynews.com

Dropbox account takeovers via Lenovo ID email-verification flaw - ~5,000 accounts, none had MFA

HIGH

VERIFIED

Federation

AccountTakeover

IdentityTrust

Between **4 and 21 August**, an unauthorised party exploited a weakness in Lenovo's email-verification process to register Lenovo IDs asserting victims' email addresses, then used Dropbox's Lenovo Identity Provider integration to sign in to the matching Dropbox accounts without the password - viewing accounts and in some cases downloading files. Many victims had never created a Lenovo account. **Every compromised account lacked MFA**. Neither company was breached and no code-execution bug existed: the vulnerability lived in the seam between two correctly-functioning systems, because Dropbox treated 'Lenovo says this user owns this email' as proof of ownership and Lenovo's verification did not establish it. Dropbox expired all Lenovo-authenticated sessions and now requires the Dropbox password alongside Lenovo ID.

Refs: bleepingcomputer.com · cybersecuritynews.com · computing.co.uk

Slovakia - Russian SMS backdoor found in 279 EU-funded NERO R-ONE traffic cameras

HIGH

VERIFIED

SupplyChain

Government

Espionage

Slovakia's NBU found backdoors in **279 NERO R-ONE enforcement cameras** bought through a EUR 30M EU-backed modernisation fund. An SMS from any of **12 Russian phone numbers** (St Petersburg and Kemerovo regions) triggers full control of live camera feeds without an IP address or password. NBU assesses the units are rebadged **Cordon.Pro.M** complexes built in St Petersburg by 'Semicon', procured through a no-bid deal with Sodasus, a Cyprus shell company with fabricated certifications. SecureBoot is disabled so firmware origin is never enforced, the management portal carries multiple vulnerabilities, and live streams are exposed without a password to anyone who knows the broadcasting IP. Installed units have been deactivated pending independent audit. **Promoted from single-source to verified this week.**

Refs: tomshardware.com · cybernews.com · risky.biz

Association des Maires de France - 114,465 elected officials and staff leaked via SQL injection

HIGH

VERIFIED

Government

SQLi

France

The AMF confirmed on 04 Sep a leak claimed earlier that day on a criminal forum by an actor using the handle '**Alduin**', who describes a UNION-based SQL injection against the association's database. **114,465 people** are affected - mayors, elected officials, directors general of services, HR staff, lawyers, administrative managers and project officers - and **one table stores passwords in cleartext**. CNIL notified; individual notification pending audit. A small IT estate carrying outsized value: a concentrated directory of local-government decision-makers, and an impersonation position trusted by every commune in France.

Refs: clubic.com · incyber.org · fuitesinfos.fr

Manchester Airports Group - 8.8M people's data leaked after ransom refusal (~550GB)

HIGH

VERIFIED

Aviation

Extortion

UK

Data on 8.8 million people was published after MAG - operator of Manchester, London Stansted and East Midlands airports - refused to pay; roughly 550GB. Initial access is claimed to have come via **exposed administrative keys**. Among the larger UK consumer breaches of 2026, and a clean data point for the 'refuse and get leaked' branch of the extortion decision tree. Tracked in this window as an update to the 26-28 August breach roundup.

Refs: bleepingcomputer.com · therecord.media · bleepingcomputer.com

Novocure - 1,400+ US cancer patients and employees exposed in mid-August attack (SEC 8-K)

MEDIUM

VERIFIED

Healthcare

Oncology

Disclosure

Disclosed in a 01 Sep Form 8-K: a mid-August cyberattack exposed data for an undisclosed number of employees and 1,400+ US patients. Most patient records held ID numbers without names; for fewer than 50 patients in the western US, identifying information and healthcare-provider contact details were accessed. No unauthorised access to medical treatment devices and no operational impact. **Do not triage this by record count**. The population is identifiable oncology patients, where the exposed fact is a diagnosis - the harm model is discrimination, extortion and disclosure to family or employers, none of which scale with volume.

Refs: bleepingcomputer.com · hipaajournal.com · sec.gov

Hopital prive de la Loire - EUR 500,000 CNIL fine under GDPR Art.32 after 727,000 people exposed

MEDIUM

VERIFIED

Regulatory

GDPR

Healthcare

CNIL fined the Saint-Etienne hospital (Ramsay Sante group) EUR 500,000 over a summer 2025 breach exposing **524,867 patients and 202,246 designated trusted third parties**. The named control failures: external users including private-practice physicians could access the system **without VPN or MFA**; access controls let one compromised account reach records for all hospital patients; and there was no real-time or near-real-time monitoring, so the attacker explored and extracted over several days undetected. The legal basis is the part worth reading - **GDPR does not penalise being breached, it penalises failing to implement measures appropriate to the risk**. An Article 32 finding means a regulator examined the control environment and found it deficient.

Refs: cnil.fr · bleepingcomputer.com · tech-insider.org

VantaCore - new pro-Ukraine group running custom ransomware against Russian companies (7 victims)

MEDIUM

UNVERIFIED

Ransomware

Hacktivism

Russia

Russian vendor F6 reports at least seven victims of a new group calling itself VantaCore, using custom ransomware against Russian companies. Two caveats stated plainly. **Source:** a Russian vendor reporting on attacks against Russian companies by a pro-Ukraine actor - not wrong, and F6 has domestic visibility no Western vendor has, but victimology, naming and framing all sit inside a conflict the reporter is party to. **Scale:** seven victims is a vendor-visible sample, not a campaign size. Single-source - unverified.

Refs: therecord.media

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-75650	CVE	StyleSmuggler Magento/Adobe Commerce pre-auth RCE 0-day (10.0); exploited from 09-04; APSB26-146 hotfix	sansec.io
CVE-2026-67276 / CVE-2026-86060	CVE	MikroTrick RouterOS unauth SSH takeover; exploited since 09-02	cert.pl
SSH user "-2"; account named "ops"	Account artefact	MikroTik post-exploitation - hunt on RouterOS devices	securityaffairs.com
CVE-2026-9586	CVE	Sangoma Switchvox unauth SQLi to RCE (9.3); CISA KEV; fix 8.4.0.2	helpnetsecurity.com
CVE-2026-82329	CVE	JFrog Artifactory auth bypass, admin-token minting (9.8); KEV 09-02; fix 7.161.20	bleepingcomputer.com
CVE-2026-83548 / CVE-2026-83549	CVE	SonicWall SMA1000 0-day chain; pre-auth SSRF 10.0; CISA KEV	securityweek.com
CVE-2026-19490 / CVE-2026-19489	CVE	Citrix NetScaler ADC/Gateway auth bypass (9.3); now exploited	cyber.gc.ca
CVE-2026-62911	CVE	MS Exchange auth bypass, all-mailbox hijack; ~22k unpatched; exploit code public	helpnetsecurity.com
CVE-2026-85046	CVE	Chrome V8 type confusion 0-day, exploited; update to 152.0.7977.75+	securityweek.com
CVE-2026-0768	CVE	Langflow unauth Python exec as root (9.8); probes for OPENAI_API*/AWS_* keys	bleepingcomputer.com
CVE-2026-32475 / CVE-2026-19949	CVE	Elementor Pro & All-in-One WP Migration RCE; mass WordPress exploitation	securityweek.com
CVE-2026-63077	CVE	JetBrains TeamCity deserialisation RCE (9.8) used to breach JetBrains Cadence	thehackernews.com
CVE-2026-72898	CVE	Metabase SQLi 0-day (10.0) behind the ShipMonk/Trezor exposure; ShinyHunters	thehackernews.com
CVE-2026-6471	CVE	PostgreSQL logical decoding dlopen to RCE; audit REPLICATION grants	postgresql.org

Indicator	Type	Context	Reference
CVE-2026-84115	CVE	Cleo Harmony JWT refresh-token privesc (8.3); public exploit; fix 5.8.1.11	securityweek.com
AS62390 (NexonHost) announcing 162.55.80.0/24	BGP hijack	Virtualizor malicious update route; Hetzner/Softaculous block	thehackernews.com
root SSH key + systemd Java service + user "proxyuser"	Host artefact	Virtualizor poisoned-update persistence on hypervisors	bleepingcomputer.com
registry[.]coder[.]com modules pulled 2026-08-31 07:35-21:45 UTC	Malicious modules	Coder registry hijack - credential-stealing Terraform modules	bleepingcomputer.com
Packagist namespaces: vsmov, vsphim, haiau009, chilltvcms, ophimcms	Malicious packages	13 Composer themes; iOS spyware stealing wallet seeds	socket.dev
178.128.87[.]160:3000 (exposed NextChat)	IP / service	Unit 42 CL-CRI-1131 operator LLM instance	unit42.paloaltonet.works.com
62.171.185[.]97 ; 165.22.184[.]26	IP	Unit 42 CL-CRI-1131 exfiltration and pivot infrastructure	unit42.paloaltonet.works.com
4e218e70afdbb116209ec0ebe8fc556e296e69648aa4e0425b83c0e863a8fee5	SHA-256 (TLS cert)	Unit 42 LATAM cluster certificate procurement artefact	unit42.paloaltonet.works.com
U+E0000-U+E007F (Unicode Tags block) in mail bodies	Unicode artefact	ASCII smuggling phishing evasion; ~150 domains, 1.3M msgs/day	microsoft.com
*[.]com[.]cn / *[.]hl[.]cn counterfeit vendor download sites	Domain pattern	Silver Fox-aligned installers; hash changes per download	microsoft.com
ProManager, WinUpdate, SoftManager, LockAppHost	Module names	REVSTEALER persistence after stealer self-deletes; Defender kill + miner	thehackernews.com
BNB Smart Chain testnet smart-contract payload fetch	C2 technique	EtherHiding ClickFix across 5,400+ hacked sites; WebRTC C2 variant	bleepingcomputer.com
C:\ProgramData\Faronics\Logs\ScriptRunner.log ; ScreenConnect off-policy	Host artefact	Faronics Deploy RMM abuse; check the "ck" parameter for rogue accounts	huntress.com
HAProxy 2.8.12 binary hash drift; trojanised crond/agetty/atd/sshd/polkitd	Binary integrity	'ted' backdoor, DPRK/APT37 overlap, South Korea	rapid7.com
12 Russian MSISDNs (St Petersburg / Kemerovo) as SMS trigger	Phone numbers	NERO R-ONE / Cordon.Pro.M camera backdoor, Slovakia	tomshardware.com
git core.fsmonitor / core.pager / diff.*.textconv in untrusted repos	Config artefact	GitSpawn - AI coding agents execute repo-supplied commands	manifold.security

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Exploitation is arriving before disclosure, and increasingly before a CVE exists

Why it matters: StyleSmuggler was attacked on 4 Sep and disclosed on the 5th with no CVE and no patch; MikroTrick was exploited from 2 Sep and disclosed on the 5th with no CVE assigned; Switchvox and JFrog were both abused within days of a fix. Triage processes keyed to a CVE identifier and a CVSS score have nothing to consume in the window that matters most.

Watch for: vendor and national-CERT advisories that carry no CVE (Sansec, CERT Polska, CCCS relays); CISA KEV additions; edge-appliance and e-commerce logs for the disclosure-minus-72-hours window rather than from the advisory date forward.

HIGH**Supply chain attacked below the artefact - route, registry endpoint and vendor CI**

Why it matters: In one week: a BGP hijack (AS62390 announcing a Hetzner /24) delivered a root-level Virtualizor update; Coder's Cloudflare origin pool was repointed for 14 hours to serve credential-stealing Terraform modules; and JetBrains was breached through its own unpatched TeamCity, exposing AWS IAM credentials and a 2024 Cadence backup. Package signing and provenance addressed none of these, because in each case the trusted thing was the path or the endpoint, not the package.

Watch for: update clients that do not cryptographically verify packages; unexpected BGP more-specific announcements for your vendors' prefixes; registry resolution to unfamiliar IPs; secrets and OIDC tokens reachable from build agents; CI servers running behind the vendor's own advised patch level.

HIGH**AI agents are now an operational attack capability, not a research result**

Why it matters: Unit 42 worked a live IR where agents ran 50+ ATT&CK; techniques and breached an enterprise in under 10 hours with no zero-day. Forescout ported a five-year-old pre-auth PLC exploit to a new hardware model for \$535.74 - the cost that used to protect OT via model fragmentation. Manifold's GitSpawn showed seven CLI coding agents executing repo-supplied commands outside their sandbox, and SpecterOps published a distributable red-team AI skills marketplace.

Watch for: agent runners with broad credentials or cloud roles; repositories arriving as files with .git intact (archives, sync folders, USB); AI gateways and dev platforms exposed to the internet; anomalous velocity in intrusion timelines; API-key sprawl on hosts that run agents.

HIGH**Implants living beneath the inspection layer - NOS, web server, load balancer, roadside device**

Why it matters: The 'ted' backdoor was compiled into victims' own HAProxy binaries in South Korea; Gambling Goblin loaded rogue Apache modules on Brazilian government servers; Fire Ant sat in Cisco IOS XR and TACACS; HPE AOS-CX and Cisco Nexus RCE put attackers in the switch OS; and Slovakia found an SMS-triggered backdoor in 279 traffic cameras. None of these produce a new file, a new service or a process-tree anomaly.

Watch for: binary hash drift against known-good builds (rpm -V / dpkg --verify / vendor checksums) on load balancers, web servers and network gear; Apache/NGINX module configuration changes; unexplained selective traffic behaviour; SecureBoot disabled on procured devices.

MED**Identity and verification data is becoming the highest-value breach class**

Why it matters: 153M driver's licence scans traced to IDScan.net (FBI investigating, 8+ class actions), 9.5M patients at Aesto Health including SSNs, sealed court filings from Thomson Reuters C-Track, and 114,465 French elected officials with cleartext passwords. None of this is rotatable, and much of it is held by processors the data subject never chose.

Watch for: third-party and processor inventories for identity-verification, archival and fulfilment vendors; deletion attestations that cover only first-party systems; account-recovery flows that treat a document scan or a federated assertion as proof of identity.

MED**Federation and MFA gaps, not cryptography, are where account takeover happens**

Why it matters: Every compromised Dropbox account lacked MFA, and the takeover ran through Lenovo ID's email-verification weakness rather than any Dropbox bug. Separately, 39 documented methods compromise passkey deployments through prompts, sync, enrolment and recovery while FIDO2 cryptography stays intact. The ACSC's MFA campaign this week is the right message aimed at the wrong layer if federated paths are excluded.

Watch for: federated sign-in paths that bypass your MFA policy; IdPs whose email verification you have never tested; passkey enrolment and recovery flows; help-desk reset procedures; sessions authenticated via third-party identity providers.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Magento/Adobe Commerce APSB26-146 hotfix (CVE-2026-75650) and rotate the encryption key plus everything it protected; MikroTik RouterOS (CVE-2026-67276/-86060); Switchvox 8.4.0.2; Artifactory 7.161.20; SonicWall SMA1000; Citrix NetScaler 14.1-73.32 / 13.1-63.21; Exchange (CVE-2026-62911); Chrome 152.0.7977.75+ and Firefox 155 / ESR branches; Elementor Pro 4.2.2 and All-in-One WP Migration; Cisco Nexus 9000 & IOS XR; HPE AOS-CX; VMware Workstation/Fusion 26H1u1; GeoNetwork 4.2.17 / 4.4.12; PostgreSQL 18.6/17.11/16.15/15.19/14.24; Cleo Harmony 5.8.1.11; Plesk 18.0.79.9 / 18.0.80.5; N-able N-central Hotfix 2.
Block IOCs	Import the IOC table into firewall/EDR/SIEM: the CVE list for alerting, the Packagist namespaces and Coder registry window, the Virtualizor persistence artefacts (root SSH key, proxyuser, systemd Java service), the MikroTik 'ops'/'-2' accounts, the .com.cn / .hl.cn counterfeit download pattern, the REVSTEALER module names, the Unit 42 LATAM IPs and certificate hash, and the Faronics ScriptRunner.log path. Alert on Unicode Tags (U+E0000-U+E007F) anywhere in inbound mail.
Assume compromise	Treat internet-exposed Magento/Adobe Commerce, MikroTik with public SSH, Switchvox, Artifactory, SMA1000, NetScaler and unpatched Exchange as potentially compromised. Hunt webshells, minted admin tokens, new privileged accounts and backdoored templates; rotate appliance and integration secrets.
Supply chain	Verify update clients cryptographically check packages (Virtualizor did not). Rotate every secret reachable by a Terraform provisioner that touched registry.coder.com on 31 Aug, and every credential used in JetBrains Cadence executions. Rebuild anything pulled from the affected Packagist namespaces. Patch CI servers ahead of application servers, not behind them.
AI & agents	Do not treat an off-the-shelf VM as a containment boundary for cyber-capable agents (Trail of Bits). Patch coding agents against GitSpawn and avoid opening repositories that arrive as files with .git intact. Scope agent credentials least-privilege and require human approval for destructive or outbound actions. Restrict exposure of LLM gateways and rotate reachable provider keys.
Identity	Enforce MFA on every sign-in path including federated ones, and test whether your IdPs actually verify email ownership. Audit passkey enrolment and recovery, not just the FIDO2 ceremony. Audit who holds PostgreSQL REPLICATION. Review deletion attestations against processors, not just first-party systems.
Detection engineering	Build the five-event AD correlation chain from the Qualys walkthrough (spray to Kerberoast to DCSync to ACL change to Golden Ticket) keyed on identity, source IP and Logon ID. Add binary-hash drift checks for HAProxy, Apache modules and network OS images. Treat an LLM analysis refusal as a signal, not a null result (GuardBreaker).